

THREAT MODELING & VULNERABILITY ASSESSMENT

IPB SPACE: CAMPUS FACILITY & QUEUE SYSTEM

*IDENTIFIKASI ANCAMAN DAN EVALUASI KERENTANAN ARSITEKTUR
PERANGKAT LUNAK*



Disusun Oleh:

KELOMPOK 4

- | | |
|---------------------------|---------------|
| 1. Naufal Ghifari Afdhala | (G6401231029) |
| 2. Samuel Christian | (G6401231037) |
| 3. Muhammad Farhadh | (G6401231080) |

**DEPARTEMEN ILMU KOMPUTER
FAKULTAS MATEMATIKA DAN ILMU PENGETAHUAN ALAM
INSTITUT PERTANIAN BOGOR
BOGOR
2026**

Daftar Isi

BAB 1: DESKRIPSI SISTEM	3
Latar Belakang Masalah	3
Gambaran Umum Sistem	3
Tujuan Implementasi Keamanan	4
Arsitektur Sistem (3-Tier Hardened Architecture)	4
Fitur Inti Keamanan Sistem	5
Manajemen Konflik Jadwal Konkuren (Concurrency Guard)	5
Sandbox Inspektor Integrasi RSA	5
BAB 2: IDENTIFIKASI ASET & BATASAN KEPERCAYAAN	6
Aset Data	6
Aset Layanan (API Endpoint Boundary)	6
Aset Infrastruktur & Kunci Rahasia	7
Model Kepercayaan dan Batas Akses (Trust Boundaries)	7
Matriks Otorisasi Peran Aktor (Role-Based Access Control)	7
BAB 3: STACK DAN DEPENDENSI KUNCI	8
Dependensi Keamanan Backend (FastAPI Ecosystem)	8
Dependensi Keamanan Frontend (React / Vite Ecosystem)	9
BAB 4: MEKANISME KEAMANAN UTAMA & IMPLEMENTASI PROTOKOL	10
Protokol Autentikasi Aman (AAA: Authentication)	10
Formulasi Hashing Kata Sandi (Bcrypt)	10
Kebijakan Isolasi Serangan (Account Lockout Policy)	10
Protokol Otorisasi Sesi (AAA: Authorization)	10
Manajemen Siklus Hidup Token JWT	10
Isolasi Endpoint via FastAPI Guards	11
Protokol Akuntansi & Forensik Siber (AAA: Accounting)	11
Perlindungan Data Diam (Data at Rest: AES-256-GCM)	11
Jaminan Nir-sangkal Dokumen (Digital Signature: RSA-PSS)	11
Alur Penandatanganan (Signing Process)	11
Alur Verifikasi (Verification Process)	12
Analisis Kinerja & Ketahanan Sistem	12
BAB 5: MITIGASI KERENTANAN OWASP TOP 10	13
A01:2021 - Broken Access Control (Mitigasi BOLA & BFLA)	13
A03:2021 - Injection (Mitigasi SQL Injection & Cross-Site Scripting)	13
BAB 6: LOG PENGUJIAN KEAMANAN & ANALISIS FORENSIK	13
Visualisasi Aliran Protokol Validasi Siber	13
Interpretasi Prosedural Diagram Siklus Hidup Keamanan	14

BAB 1: DESKRIPSI SISTEM

Latar Belakang Masalah

Transformasi tata kelola administrasi sarana dan prasarana kampus dari metode konvensional (seperti pencatatan manual pada buku log fisik atau koordinasi tidak terstruktur via WhatsApp group) menuju platform digital terpusat melahirkan sebuah ekosistem yang rentan terhadap ancaman siber. Platform peminjaman fasilitas publik skala universitas seperti **IPB Space** mengelola aset data yang bersifat kritis, termasuk data identitas civitas akademika (*Personally Identifiable Information* - PII) serta dokumen legalitas permohonan izin penggunaan ruangan.

Ketiadaan penguatan keamanan (*security hardening*) pada fase perancangan perangkat lunak dapat mengekspos arsitektur sistem terhadap berbagai kerentanan kritis. Dokumen proposal permohonan berbentuk PDF rawan dimodifikasi secara ilegal oleh pihak luar atau pengguna yang tidak berhak jika disimpan tanpa proteksi integritas. Di sisi lain, mekanisme otentikasi tradisional sangat rentan terhadap serangan otomatis massal seperti *automated brute force*, *credential stuffing*, dan pembajakan sesi (*session hijacking*). Tanpa adanya pencatatan log siber yang persisten, sistem akan mengalami kebutaan forensik (*blind-spot audit*) yang mempersulit investigasi apabila insiden siber terjadi di kemudian hari.

Oleh karena itu, Kelompok 04 merancang dan menerapkan sebuah kerangka penguatan keamanan berlapis berbasis standar industri **OWASP (Open Worldwide Application Security Project) Top 10** dan **Protokol AAA (Authentication, Authorization, & Accounting)**. Pengamanan ini diintegrasikan secara langsung di dalam alur kerja utama (*main workflow*) backend maupun frontend aplikasi pada lingkungan produksi **cloud**, mewujudkan prinsip **Security by Design**.

Gambaran Umum Sistem

IPB Space dikembangkan sebagai platform peminjaman fasilitas kampus terintegrasi yang andal, aman, dan transparan bagi seluruh civitas akademika IPB University (Mahasiswa, Dosen, Pegawai, dan Pengelola Fasilitas). Untuk menjamin keamanan end-to-end, sistem ini menyajikan lima komponen penguatan utama yang dapat diaudit secara visual:

1. **Security Cryptographic Audit Panel:** Halaman profil pengguna yang mengekstrak dan menampilkan 22 karakter pertama dari string *Salt* biner kustom hasil produksi generator acak semu internal sistem operasi secara transparan untuk kebutuhan audit mandiri pengguna.
2. **Dynamic Password Entropy Meter:** Komponen interaktif pada antarmuka pengguna yang menghitung kekuatan bit entropi kata sandi secara *real-time* di sisi klien untuk mencegah penggunaan kata sandi yang lemah dan mudah ditebak.
3. **Storage Security Vault & Integrity Alarm:** Kompartemen penyimpanan berkas aman di server yang mengubah dokumen proposal PDF menjadi berkas biner terenkripsi penuh (.secured), dilengkapi dengan indikator alarm visual siber yang akan berkedip merah jika mendeteksi adanya mutasi bit atau manipulasi berkas pada media penyimpanan disk.
4. **SOC Security & Audit Analytics Dashboard:** Panel kontrol administratif Super Admin untuk memantau metrik agregat siber secara *real-time*, mendeteksi anomali percobaan login ilegal, serta mengawasi beban performa infrastruktur kriptografi.
5. **Emergency Account Recovery Panel:** Instrumen pemulihan darurat terisolasi yang dipegang oleh Super Admin untuk memulihkan status akun civitas akademika yang terkunci

akibat kebijakan pembatasan salah login secara instan menggunakan parameter email yang bersifat *reseed-proof*.

Tujuan Implementasi Keamanan

- **Confidentiality (Kerahasiaan):** Melindungi data sensitif profil civitas dan berkas lampiran izin agar tidak dapat dibaca oleh pihak eksternal, baik saat data berpindah melalui jaringan internet maupun saat data diam di dalam disk penyimpanan basis data.
- **Integrity (Integritas):** Menjamin bahwa data transaksi, jadwal pemakaian ruang, dan berkas permohonan tidak dapat dimodifikasi atau dimanipulasi tanpa terdeteksi oleh sistem keamanan pusat.
- **Availability (Ketersediaan):** Menjamin ketersediaan sistem dari risiko kelumpuhan server (*crash*) akibat pemboman request login massal atau kondisi balapan data (*race condition*) pemesanan jadwal ganda.
- **Accountability (Akuntabilitas):** Menciptakan rantai rekam jejak aktivitas birokrasi permanen yang kebal manipulasi (*Immutable Audit Trail*) untuk mengeliminasi penyangkalan tindakan (*non-repudiation*) oleh aktor sistem.

Arsitektur Sistem (3-Tier Hardened Architecture)

Platform diimplementasikan menggunakan arsitektur tiga lapisan yang terisolasi secara ketat pada lingkungan produksi cloud untuk meminimalkan permukaan serangan (*attack surface*):

Lapisan Arsitektur	Komponen Teknologi	Fungsi & Penerapan Kontrol Keamanan
Frontend Layer	React 19, Vite 7, Tailwind CSS	Antarmuka reaktif yang di-host di Vercel Edge Network. Menangani client-side routing, pembatasan navigasi RBAC, kalkulasi live bit entropi, dan sanitasi elemen UI dari celah Cross-Site Scripting (XSS).
Backend Layer	FastAPI (Python 3.10), Uvicorn	Mesin logika bisnis utama yang di-host di Railway Cloud Container. Menangani interceptor middleware, validasi strict type data payload, operasi kriptografi simetris/asimetris, dan delegasi logging asinkron.
Data Layer	Cloud PostgreSQL	Penyimpanan data relasional terpusat untuk menyimpan entitas data pengguna, tabel booking, konfigurasi ruangan, dan basis log forensik siber.
Protokol AAA	Bearer JWT Token, Bcrypt 12	Pemisahan sesi melalui token JWT berumur pendek (Access 30 menit & Refresh 7 hari).

		Hashing password menggunakan pengacakan berulang 4.096 iterasi.
Kriptografi Modern	AES-256-GCM, RSA-PSS 2048	Enkripsi berkas PDF menggunakan sandi blok simetris AES-GCM dan pembuatan tanda tangan digital menggunakan skema probabilistik asimetris RSA-PSS (SHA-256).
Accounting Engine	Structlog, BackgroundTasks	Logging terpisah: Penulisan event makro secara instan ke app_logs.txt dan log mikro detail (IP, Browser) ke database via task non-blocking FastAPI.

Fitur Inti Keamanan Sistem

Manajemen Konflik Jadwal Konkuren (Concurrency Guard)

Sistem memblokir celah manipulasi jadwal ganda (*double booking* atau *phantom booking*) akibat kondisi balapan data ketika ratusan pengguna menembak satu slot ruangan favorit pada milidetik yang sama. Backend FastAPI menerapkan skema *asynchronous database locking* melalui formula deteksi irisan waktu formal:

$$S < E_{\text{existing}} \text{ dan } E > S_{\text{existing}}$$

Di mana S mewakili waktu mulai (*start time*) pengajuan baru dan E mewakili waktu selesai (*end time*) pengajuan baru. Jika query basis data mendeteksi adanya irisan nilai pada hari dan ruangan yang sama, pengajuan yang kalah cepat dalam hitungan milidetik akan langsung ditolak secara aman, dibatalkan dari transaksi utama, dan dialirkan secara otomatis ke dalam antrean daftar tunggu berdasarkan prinsip *First-In-First-Out* (FIFO).

Sandbox Inspektur Integrasi RSA

Sistem menyediakan modul visualisasi prosedural bagi Manager Fasilitas untuk membedah pembuktian matematis keaslian tiket digital civitas secara transparan langsung pada layar. Komponen ini memvisualisasikan empat tahap isolasi: serialisasi string teks manifes asli, komputasi live SHA-256 digest, dekripsi tanda tangan menggunakan kunci publik RSA server, hingga penjatuhan keputusan status integritas dokumen.

BAB 2: IDENTIFIKASI ASET & BATASAN KEPERCAYAAN

Aset Data

Identifikasi aset data dilakukan untuk memetakan seluruh entitas informasi sensitif yang dikelola oleh platform IPB Space, dilengkapi dengan klasifikasi risiko kerugian institusi jika aset tersebut terekspos:

Entitas Data	Data	Komponen	Atribut Sensitif Terproteksi	Nilai Risiko
Kredensial Otorisasi		Tabel DB users	Password (Bcrypt Ciphertext), Email Resmi, NIM/NIP, Token JWT Aktif	KRITIS
Berkas Dokumen	Vault	Server Storage	File .secured (Raw Ciphertext AES-256-GCM)	TINGGI
Jejak Forensik	Log	Tabel DB login_logs	IP Address Gateway, User-Agent String, Request ID UUID	TINGGI
Transaksi Birokrasi		Tabel DB bookings	Digital Signature String, Status Approval, Keterangan Validator	SEDANG
Master Kampus	Sarana	Tabel DB facilities	Kontak Person Narahubung, Kode Ruang, Kapasitas Total	SEDANG

Aset Layanan (API Endpoint Boundary)

Seluruh gerbang komunikasi REST API dilindungi secara granular di tingkat server menggunakan intersektor middleware untuk mencegah celah **Broken Object Level Authorization (BOLA)**:

Endpoint API Gateway	Metode	Fungsi Layanan & Batas Kendali Otorisasi
/api/v1/auth/login	POST	Otentikasi kredensial pengguna, penerbitan token JWT ganda, inisiasi pencatatan log siber.
/api/v1/users/me/security-audit	GET	Ekstraksi 22-karakter Bcrypt Salt akun civitas aktif untuk audit mandiri.
/api/v1/bookings	POST	Pengajuan reservasi baru oleh Civitas disertai pemanggilan otomatis modul enkripsi berkas AES.
/api/v1/bookings/{id}/approve	POST	Validasi keputusan tingkat Manager disertai pembubuhan tanda tangan privat RSA-PSS.
/api/v1/system/security-policy	GET	Penarikan visualisasi live status pengerasan runtime sistem (Khusus Super Admin).
/api/v1/users/unlock-by-email	POST	Eksekusi darurat pemulihan status akun terisolasi akibat lockout (Khusus Super Admin).

Aset Infrastruktur & Kunci Rahasia

Komponen fisik dan variabel lingkungan (*environment variables*) yang memegang peranan vital dalam menjaga kerahasiaan operasi enkripsi global aplikasi:

- **JWT Secret Key (Nilai: KRITIS):** String rahasia berkekuatan entropi tinggi untuk menandatangani dan memverifikasi integritas payload token sesi klien.
- **RSA Private Key (Nilai: KRITIS):** Kunci asimetris 2048-bit rahasia milik server backend untuk menghasilkan tanda tangan digital pada dokumen izin.
- **OS Environment Container (.env) (Nilai: KRITIS):** Lapisan isolasi fisik di infrastruktur cloud Railway untuk menyembunyikan seluruh kunci kriptografi agar terhindar dari kelalaian indeks publik Git (.gitignore enforced).

Model Kepercayaan dan Batas Akses (Trust Boundaries)

Platform IPB Space mengisolasi wilayah operasionalnya ke dalam tiga zona batasan kepercayaan secara tegas:

1. *Zona Publik:* Wilayah luar jaringan (Internet Publik / Klien yang belum terautentikasi). Hanya diizinkan melakukan pembacaan katalog umum dan menembak rute otentikasi login.
2. *Zona Terautentikasi (JWT Boundary):* Wilayah internal aplikasi browser klien yang memegang klaim token sesi sah. Pergerakan antarhalaman dikontrol ketat oleh skema kontrol akses berbasis peran (**Role-Based Access Control** - RBAC).
3. *Zona Internal Data Store:* Wilayah komunikasi eksklusif berkadar kepercayaan tertinggi yang menghubungkan logika bisnis backend FastAPI dengan cluster database PostgreSQL menggunakan enkripsi TLS internal.

Matriks Otorisasi Peran Aktor (Role-Based Access Control)

Isolasi hak akses fitur dipetakan secara granular untuk memastikan penegakan asas *Separation of Duties* berjalan sempurna:

Fitur Utama Sistem	Tamu	Civitas	Manager	Super Admin
Eksplorasi Kalender & Katalog Publik	✓	✓	✓	✓
Evaluasi Bit Entropi Kata Sandi	-	✓	-	-
Pengajuan Reservasi & Enkripsi Berkas	-	✓	-	-
Verifikasi Kriptografi RSA-PSS Tiket	-	-	✓	-
Otorisasi Validasi Dokumen Izin	-	-	✓	-
Audit Forensik Dashboard SOC	-	-	-	✓
Emergency Identity-based Account Unlock	-	-	-	✓
CRUD Manajemen Akun Pengguna Global	-	-	-	✓

BAB 3: STACK DAN DEPENDENSI KUNCI

Untuk menjamin kepatuhan sistem terhadap prinsip **Zero Trust Architecture** di lingkungan produksi cloud, pemilihan pustaka (*library*) dan dependensi pada platform IPB Space disaring secara ketat berdasarkan rekam jejak pemeliharaan keamanan serta efisiensi performanya.

Dependensi Keamanan Backend (FastAPI Ecosystem)

Lapisan backend FastAPI memanfaatkan ekosistem Python modern yang berfokus pada validasi tipe data secara ketat (*strict type enforcement*) dan abstraksi primitif kriptografi tingkat rendah:

Paket Ekstensi Backend	Versi	Peran / Fungsi Keamanan	Pengerasan
fastapi	0.128.0	Framework REST API utama, mendukung dependency injection untuk otorisasi dan kontrol akses rute.	
sqlalchemy	2.0.46	ORM relasional aman yang mengimplementasikan parameterized queries secara otomatis untuk mencegah serangan SQL Injection.	
alembic	1.18.3	Manajemen migrasi skema database relasional secara terversi untuk menjaga konsistensi state basis data.	
pydantic	2.12.5	Validasi input data terikat (<i>strict type validation</i>) dan sanitasi data request untuk mencegah buffer overflow.	
bcrypt	5.0.0	Hashing password satu arah menggunakan algoritma Blowfish Crypt dengan parameter salt dinamis tingkat sistem operasi.	
PyJWT	2.10.1	Penerbitan dan pemetaan token JSON Web Token (JWT) untuk pertukaran klaim otorisasi sesi secara aman.	
cryptography	46.0.4	Implementasi algoritma asimetris RSA-PSS 2048-bit untuk digital signature dan simetris AES-256-GCM.	
structlog	Latest	Pencatatan log terstruktur berkinerja tinggi untuk dialirkan langsung ke dalam file app_logs.txt.	

Dependensi Keamanan Frontend (React / Vite Ecosystem)

Frontend React 19 yang dibundel menggunakan Vite 7 dirancang untuk menyajikan data secara dinamis, mengelola interaksi pengguna, dan menerapkan kontrol keamanan sisi klien (*client-side protection*):

Paket Ekstensi Frontend	Versi	Peran / Fungsi Pengerasan Keamanan
react	^19.2.0	Perpustakaan UI komponen utama yang memanfaatkan Contextual Auto-Escaping untuk meredam celah Cross-Site Scripting (XSS).
react-router-dom	^7.13.0	Pengelolaan client-side routing dan proteksi pembatasan akses halaman berbasis peran (RBAC Wrapper).
axios	^1.13.4	Klien HTTP dengan interceptor ganda untuk menyematkan token JWT secara otomatis pada Authorization header.
react-qr-code	^2.0.21	Generator QR Code sisi klien untuk memvisualisasikan muatan data tiket digital terenkripsi dan signature.
html-to-image	^1.11.13	Utilitas konversi komponen tiket digital menjadi gambar biner PNG terisolasi tanpa API call eksternal.

BAB 4: MEKANISME KEAMANAN UTAMA & IMPLEMENTASI PROTOKOL

Protokol Autentikasi Aman (AAA: Authentication)

Sistem IPB Space memvalidasi identitas aktor melalui pendekatan defensif yang menggabungkan kalkulasi salt acak dan pembatasan kegagalan login secara mekanis di tingkat backend.

Formulasi Hashing Kata Sandi (Bcrypt)

Penyimpanan kredensial plaintext sangat dilarang dalam sistem. Kata sandi pengguna diamankan menggunakan algoritma **Bcrypt** dengan penambahan salt acak secara dinamis per pengguna. Formulasi matematis pengerasan kata sandi didefinisikan sebagai:

$$H = \text{Bcrypt}(P_{\text{raw}}, \text{Salt}_{\text{CSPRNG}}, \text{Cost Factor} = 12)$$

Di mana $\text{Salt}_{\text{CSPRNG}}$ adalah string acak sepanjang 128-bit yang diproduksi secara unik menggunakan generator bilangan acak semu tersertifikasi keamanan sistem operasi (`bcrypt.gensalt()`). Parameter faktor biaya (*Cost Factor*) dikunci pada nilai **12 Rounds**, yang berarti sistem melakukan iterasi pengacakan sebanyak $2^{12} = 4.096$ putaran. Peningkatan overhead waktu komputasi (250ms) ini sengaja diterapkan untuk melumpuhkan skenario serangan otomatis **Offline Brute Force** dan kalkulasi **Rainbow Table**.

Kebijakan Isolasi Serangan (Account Lockout Policy)

Sistem mencatat jumlah kegagalan login secara persis di database. Jika terjadi kesalahan input kata sandi berturut-turut pada endpoint `/api/v1/auth/login`, sistem menjalankan logika interseptor berikut:

1. Setiap kegagalan akan menaikkan nilai counter pada database.
2. Ketika counter mencapai batas maksimal (**5x Gagal Login**), sistem otomatis mengubah flag biner `is_locked` menjadi true.
3. Akun pengguna akan diisolasi dan dibekukan selama durasi **15 Menit**. Setiap request login baru pada masa pembekuan akan langsung ditolak dengan kode respons HTTP 423 Locked tanpa menjalankan fungsi komputasi Bcrypt untuk menghemat sumber daya CPU server.

Protokol Otorisasi Sesi (AAA: Authorization)

Otorisasi hak akses dikelola secara **stateless** menggunakan mekanisme token ganda dan penegakan rute API yang granular.

Manajemen Siklus Hidup Token JWT

Sistem memisahkan token sesi menjadi dua jenis dengan siklus penanganan yang berbeda:

- **Access Token (Umur: 30 Menit)**: Memuat payload klaim identitas (sub) dan peran otoritas (role), ditandatangani menggunakan algoritma HMAC-SHA256.
- **Refresh Token (Umur: 7 Hari)**: Digunakan untuk memperbarui token akses yang kedaluwarsa. Demi mencegah dampak kebocoran database, string asli refresh token tidak disimpan dalam format teks terang, melainkan di-hash terlebih dahulu menggunakan algoritma satu arah **SHA-256**:

$$H_{\text{refresh}} = \text{SHA-256}(\text{Token}_{\text{raw}})$$

Isolasi Endpoint via FastAPI Guards

Penegakan batas keamanan rute API diimplementasikan secara ketat menggunakan dekorator fungsi asinkron Python pada kontroler backend. Jika pengguna dengan tingkat peran rendah (Civitas) mencoba menembak rute administratif yang dilindungi oleh dekorator `ensure_is_admin` atau `ensure_is_facility_manager`, alur proses akan langsung dipotong dan server mengembalikan kode status HTTP 403 Forbidden.

Protokol Akuntansi & Forensik Siber (AAA: Accounting)

Prinsip akuntabilitas dipenuhi melalui implementasi **Arsitektur Log Dua Lapis (Dual-Layer Logging Architecture)** yang bekerja secara asinkron menggunakan fitur **Background Tasks** dari FastAPI:

1. **Layer 1: Real-time Telemetry (Activity Log):** Pencatatan makro ke dalam berkas `app_logs.txt` dengan format terstruktur JSON. Data ini dialirkan menggunakan mode bebas cache (`PYTHONUNBUFFERED=1`) untuk menyuplai grafik analitik pada **SOC Dashboard UI** secara real-time.
2. **Layer 2: Digital Forensics (Login History):** Pencatatan mikro yang menuliskan setiap riwayat login secara otomatis ke dalam tabel database `login_logs`. Atribut forensik yang ditangkap meliputi alamat IP asal (`ip_address`), string identifikasi browser/OS (`user_agent`), penanda waktu (`timestamp`), dan status hasil akses (`SUCCESS` atau `FAILED`). Setiap request diikat dengan kode unik `request_id` berbentuk *UUID v4* lintas layer untuk menjamin ketertelusuran dokumen (**traceability**).

Perlindungan Data Diam (Data at Rest: AES-256-GCM)

Untuk melindungi dokumen proposal berkas PDF yang diunggah oleh civitas dari ancaman kebocoran data, sistem mengimplementasikan enkripsi simetris tingkat militer **AES-256-GCM (Authenticated Encryption with Associated Data)**.

Proses enkripsi mengubah berkas PDF mentah menjadi berkas acak berformat `.secured` sebelum ditulis ke dalam disk penyimpanan server. Formula kriptografinya adalah:

$$C, T = \text{AES-256-GCM}_{\text{Encrypt}}(K_{\text{AES}}, N_{96}, P_{\text{document}})$$

Di mana K_{AES} adalah kunci simetris 256-bit rahasia yang diisolasi di level sistem operasi melalui **Environment Variables** cloud Railway, N_{96} adalah **Nonce** acak sepanjang 96-bit yang unik per dokumen, dan T adalah **Authentication Tag** 128-bit untuk mendeteksi manipulasi. Jika satu bit saja data biner pada berkas `.secured` diubah oleh peretas, proses dekripsi akan gagal memvalidasi tag T , sistem akan memblokir pembacaan berkas, dan memicu **Integrity Alarm** pada antarmuka sistem.

Jaminan Nir-sangkal Dokumen (Digital Signature: RSA-PSS)

Aspek anti-penyangkalan (**non-repudiation**) pada penerbitan tiket digital menggunakan skema kriptografi asimetris **RSASSA-PSS (RSA 2048-bit)** yang dikombinasikan dengan hashing **SHA-256**.

Alur Penandatanganan (Signing Process)

Ketika Manager Fasilitas menyetujui permohonan, data transaksi dikompilasi menjadi string JSON terurut (M), lalu diringkas menggunakan fungsi hash SHA-256:

$$H = \text{SHA-256}(M)$$

Nilai hash H kemudian ditandatangani menggunakan Kunci Privat RSA milik server backend dengan skema probabilistik PSS untuk menghasilkan string **Digital Signature** (S):

$$S = \text{RSA-Sign}(K_{\text{private}}, \text{PSS-Padding}(H))$$

String signature S ini ditanamkan ke dalam payload QR Code tiket digital pengguna.

Alur Verifikasi (Verification Process)

Saat check-in fisik, sistem memindai QR Code dan melakukan dekripsi signature menggunakan Kunci Publik RSA server:

$$H_{\text{decrypted}} = \text{RSA-Verify}(K_{\text{public}}, S)$$

Jika nilai $H_{\text{decrypted}}$ cocok dengan kalkulasi ulang hash SHA-256 dari data tiket aktual lapangan, maka dokumen dinyatakan sah (**Integrity & Non-Repudiation Guaranteed**).

Analisis Kinerja & Ketahanan Sistem

Evaluasi dampak implementasi penguatan keamanan dilakukan secara kuantitatif untuk memastikan pilar **Availability** aplikasi tetap terjaga:

- **Efisiensi Penyimpanan (Data Inflation):** Implementasi enkripsi AES-256-GCM dan penambahan metadata signature RSA-PSS hanya menghasilkan overhead ukuran data sebesar $< 0.05\%$ (+268 Byte) pada berkas PDF berukuran 5MB.
- **Response Time & Latency Overhead:** Durasi rata-rata pemrosesan gabungan operasi enkripsi berkas berukuran 1MB hanya membutuhkan waktu *3.10 milidetik*, sedangkan proses verifikasi dan dekripsi diselesaikan sangat cepat dalam waktu *1.92 milidetik*.
- **Beban Infrastruktur:** Saat proses kriptografi berjalan aktif, kenaikan penggunaan sumber daya server tercatat sangat rendah, yaitu hanya sebesar *+1.6% pada CPU Overhead* dan alokasi tambahan *+3 MB pada RAM Usage*. Hal ini membuktikan sistem mencapai tingkat keamanan tinggi tanpa mengorbankan kecepatan respons aplikasi.

BAB 5: MITIGASI KERENTANAN OWASP TOP 10

Sebagai bentuk kepatuhan terhadap arsitektur keamanan modern, sistem IPB Space mengonfigurasi lapis pertahanan khusus untuk meredam vektor serangan yang terdaftar pada standar kerentanan siber **OWASP Top 10**.

A01:2021 - Broken Access Control (Mitigasi BOLA & BFLA)

Kerentanan pemalsuan identitas objek rute API atau eksekusi fungsi administratif oleh akun tingkat rendah diredam secara absolut melalui dua mekanisme:

- **Server-Side Claim Validation:** Sistem tidak pernah mempercayai parameter peran yang dikirimkan oleh state frontend. Setiap eksekusi endpoint kritis wajib melalui proses dekripsi kunci simetris pada token JWT untuk mengekstrak klaim peran aktual langsung di sisi server.
- **Strict Endpoint Isolation:** Batasan hak akses diikat menggunakan dekorator fungsional di tingkat kode gerbang API, mematikan celah eksploitasi parameter manipulasi ID transaksi.

A03:2021 - Injection (Mitigasi SQL Injection & Cross-Site Scripting)

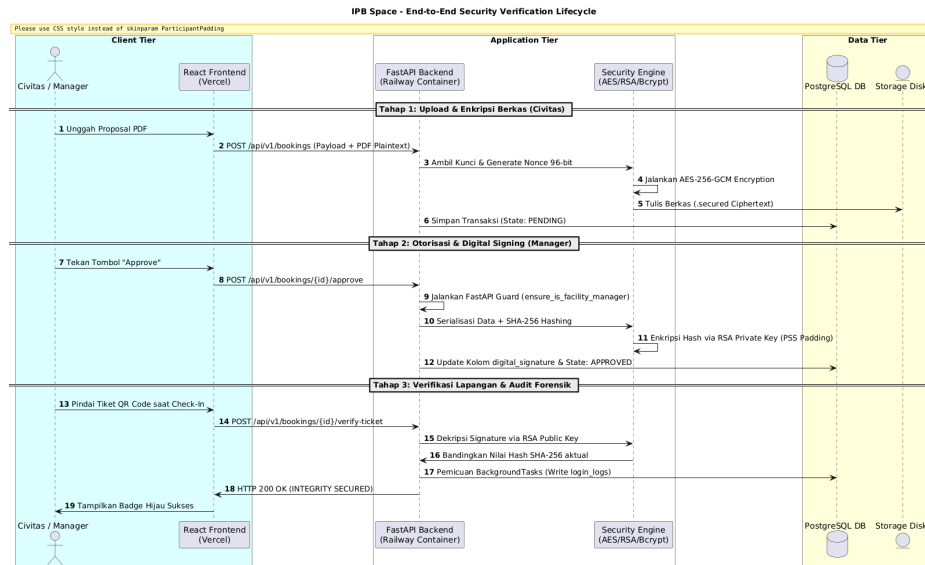
Serangan injeksi perintah basis data berbahaya dan penyisipan skrip jahat diredam secara otomatis pada level arsitektur pustaka:

- **SQLi Countermeasure:** Seluruh interaksi manipulasi data menuju cluster database PostgreSQL diwajibkan menggunakan kueri berparameter (*parameterized queries*) yang disediakan secara bawaan oleh ORM SQLAlchemy. Parameter masukan dari pengguna diperlakukan secara ketat sebagai literal data, bukan sebagai kode eksekusi kueri, sehingga melumpuhkan teknik bypass logika ‘OR 1=1 –.
- **Stored & Reflected XSS Protection:** Mesin render JSX pada React 19 menerapkan kebijakan *Contextual Auto-Escaping* secara ketat. Karakter khusus seperti < atau > otomatis dikonversi menjadi entitas HTML aman (< dan >), sehingga mencegah browser mengeksekusi skrip instruksi ilegal seperti <script>alert('XSS')</script>.

BAB 6: LOG PENGUJIAN KEAMANAN & ANALISIS FORENSIK

Visualisasi Aliran Protokol Validasi Siber

Untuk memberikan gambaran menyeluruh mengenai integrasi modul kriptografi modern (AES-256-GCM dan RSA-PSS 2048-bit) dalam siklus hidup data pada platform IPB Space, dirancang diagram alur siber terintegrasi sebagai berikut:



Gambar 3.1: Diagram Urutan Aliran Validasi Keamanan dan Siklus Hidup Kriptografi IPB Space.

Interpretasi Prosedural Diagram Siklus Hidup Keamanan

Berdasarkan tata alur Gambar 3.1 di atas, sistem menegakkan tiga fase pembuktian siber secara berurutan:

1. **Fase Konfidensialitas At Rest (Langkah 1-6):** Memperlihatkan isolasi file proposal civitas. File biner mentah PDF diacak langsung di memori server backend menggunakan sandi blok AES-256-GCM sebelum disimpan fisik ke dalam disk storage, memastikan data aman dari kebocoran penyimpanan cloud.
2. **Fase Integritas Nir-sangkal (Langkah 7-12):** Menggambarkan mekanisme saat Manager Fasilitas melakukan approval. Transaksi diikat secara matematis menggunakan kalkulasi hash SHA-256 dan dienkrpsi menggunakan kunci privat RSA server untuk menerbitkan stempel *digital signature* tak terbantahkan.
3. **Fase Deteksi Forensik & Verifikasi (Langkah 13-19):** Mengilustrasikan proses check-in lapangan. Ketika QR code dipindai, backend menggunakan kunci publik RSA untuk memverifikasi keabsahan tanda tangan secara asinkron, sembari mendelegasikan tugas pencatatan log mikro forensik ke database untuk menangkap properti fisik gawai penyerang.